

# API Test Cases

## Authentication Endpoint: POST /api/login

### Happy path

- Body: valid email + password.
- Expected: 200, returns a JWT and a refresh token.

### Missing fields

- Body: email only, no password.
- Expected: 400 with a validation message naming the missing field.

### Wrong credentials

- Body: valid email, wrong password.
- Expected: 401, no token issued, generic error message.

### Rate limiting

- Send 20 login requests in 10 seconds from one IP.
- Expected: 429 after the threshold, with a Retry-After header.

## Orders Endpoint: GET /api/orders

### Authorized

- Header: valid Bearer token.
- Expected: 200, returns the user's orders only.

### Unauthorized

- Header: no token.
- Expected: 401.

### Cross-user access

- Header: user A's token, request user B's order id.
- Expected: 403 — must not leak another user's data.

## Performance Notes

- The orders endpoint should respond under 300 ms at p95.
- Login p95 has spiked above 800 ms during peak load — see performance backlog.